Stoquify Findings Register — 2026-08-03

Summary

Priority	Count	Interpretation
P0	1	Structural tenant-isolation risk
P1	13	Financial truth, identity, audit, entitlement, query context, release, and product trust blockers
P2	12	Concurrency, privacy, integration, error, accessibility, CI, and ownership gaps
P3	1	Dependency hygiene hypothesis

Register

ID	Priority	Finding	Confidence	Value/maturity	Prior status	Owner
TEN-001	P0	No mandatory organization-scoped persistence/RLS backstop	High	DANGEROUS, 2/5	Still confirmed	Platform security/data
FIN-001	P1	POS non-cash capture/refund becomes locally final before provider authority	High	DANGEROUS, 2/5	Still confirmed	Payments/POS
FIN-002	P1	Dashboard, snapshot, and finance payment/cash/AR semantics diverge	Very high	DANGEROUS, 2/5	Still confirmed	Finance/accounting snapshots
FIN-003	P1	Finance totals are silently aggregated from capped arrays	Very high	DANGEROUS, 2/5	New	Finance read models
FIN-004	P1	Customer and drawer balances are lost-update prone	High	DANGEROUS, 2/5	Still confirmed	POS/accounting
AUD-001	P1	Security audit skips/swallow failures and is not transactionally durable	High	DANGEROUS, 2/5	Still confirmed	Security/evidence
IAM-001	P1	Invitation bearer tokens are stored and queried in plaintext	High	DANGEROUS, 2/5	Still confirmed	Identity
AUTH-001	P1	MFA enrollment/challenge and MFA-level step-up are incomplete	Very high	MISSING/DANGEROUS, 2/5	New explicit evidence	Identity/security
ENT-001	P1	Module entitlement defaults to observe/legacy access	High	DANGEROUS, 2/5	Still confirmed	Modules/commercial
POS-001	P1	Offline replay does not preserve original actor/module authority	High	DANGEROUS, 2/5	Partially remediated	Offline POS/security
QUERY-001	P1	Global query cache and many keys omit organization context	Medium-high	DANGEROUS, 2/5	New	Frontend/platform
OBS-001	P1	Default logger sink is no-op; production observability delivery unproven	High	MISSING/DANGEROUS, 2/5	Still confirmed	SRE/platform

ID	Priority	Finding	Confidence	Value/maturity	Prior status	Owner
REL-001	P1 blocker	Production migration, secret, statutory, provider, and rollback evidence blocked/unverified	High	MISSING, 2/5	Improved, still blocked	Release/platform/compliance
UX-001	P1	Broken/demo/null and duplicate routes damage product trust and supportability	High	WEAK/USELESS/DANGEROUS, 2/5	New	Product/frontend
PO-001	P2	Canonical PO approval lacks state/version CAS	High	USEFUL, 3/5	Residual after P0 fix	Purchase-order
AP-001	P2	AP active exceptions use find-then-create without uniqueness	Medium-high	USEFUL, 2/5	Still confirmed	Purchasing/AP
PRIV-001	P2	Tenant uploads are publicly cacheable, extension-typed, whole-file buffered	High	DANGEROUS, 2/5	New	Storage/security
PRIV-002	P2	Raw provider payload/retention/erasure controls are incomplete	Medium-high	DANGEROUS, 2/5	New	Privacy/payments
INT-001	P2	CSV parsing and provider timestamp contract are fragile	High	WEAK, 2/5	New	Integrations/payments
WEB-001	P2	CSP unsafe-inline and forwarded-header client IP weaken abuse controls	High	WEAK/DANGEROUS, 2/5	New	Web security
CI-001	P2	No explicit SAST/SCA/secret/SBOM/container/DAST jobs evidenced	High	MISSING, 2/5	New	DevSecOps
ERR-001	P2	Raw-error gate fails with six active findings	Confirmed	WEAK, 2/5	Current gate failure	Error platform/domain owners
TEST-001	P2	Jest open handles force worker shutdown in three focused invocations	Confirmed	WEAK, 2/5	New runtime evidence	Test platform
UX-002	P2	Authenticated shell localization and broad accessibility proof are incomplete	High	WEAK/MISSING, 2/5	Ongoing	Product/frontend/a11y
PROD-001	P2	Activation, adoption, denied-navigation, and retention telemetry absent	High	MISSING, 1/5	Ongoing	Product/data
AI-001	P2	Copilot proposal flow does not prohibit creator self-approval	High	USEFUL, 3/5	Unchanged, reduced by execution NONE	AI/agents
DEPS-001	P3	Duplicate/generic dependencies may be unnecessary	Low-medium	WEAK, 2/5	New hypothesis	Platform

Resolved or contained findings

ID	Disposition	Evidence
JULY-PO-BULK	Fully remediated at reviewed boundary	Bulk `APPROVED` rejected in action and service; actor derived server-side; focused tests passed
JULY-STORE-CREDIT	Safely contained	Store-credit tender rejected before transaction; authoritative ledger still missing
JULY-TRUSTED-ORIGIN	Fully remediated	Trusted origins now derive from normalized configuration, not request host
JULY-POS-TENDER-MODULE	Remediated	POS tender action now enforces the POS module; offline actions remain separate finding

Finding details and acceptance evidence

TEN-001

- **Roles/assets:** every tenant; all tenant-owned data and financial workflows.
- **Evidence:** `docs/architecture/decisions/0002-org-scoped-prisma-extension.md:11-23`; `prisma/db.ts:7-23`; `services/_shared/protect.ts:54,180-200`.
- **Impact/blast radius:** cross-tenant reads/writes/exports or corruption if any service omits a filter.
- **Existing controls:** DB-fresh membership/RBAC, manual service filters, action guards, service ownership.
- **Recommendation:** mandatory scoped repository/client plus composite constraints and RLS on highest-risk tables.
- **Acceptance:** adversarial tests deliberately omit/mismatch tenant filters across service/action/API/worker; all fail at persistence; reviewed unscoped inventory is explicit; migration/rollback proven.

FIN-001 / FIN-002 / FIN-003 / FIN-004

- **Roles/assets:** cashiers, owners, finance, accountants, customers, cash drawers, receivables, close.
- **Evidence:** `services/pos/pos.service.ts:1810-1824,2013-2057,2737-2760`; dashboard/snapshot/finance lines listed in whole-system audit; finance caps at `services/finance/finance-dashboard.service.ts:568-778`.
- **Impact:** fraud, false settlement, understated totals, inconsistent KPI decisions, lost balance updates, incorrect close inputs.
- **Existing controls:** local reference uniqueness, signed provider-event service, reconciliation/suspense, ledger postings, close/data-trust blockers.
- **Recommendation:** one payment-state/metric contract, provider-gated finality, DB aggregates, CAS/atomic balances.
- **Acceptance:** status truth-table shared across all projections; >300-record totals exact; two simultaneous sales/refunds reconcile to ledger; rejected/timeout provider events never post final funds.

AUD-001 / IAM-001 / AUTH-001

- **Impact:** repudiation, privileged action without durable evidence, token compromise, weak privileged authentication.

- **Recommendation:** transactional audit/outbox; digest-only one-time invitation tokens; MFA enrollment/challenge and MFA-level fresh-auth policy.
- **Acceptance:** audit outage follows an explicit fail-closed/deferred policy; raw invite token never persists; concurrent redemption produces one success; privileged workflows reject password-only assurance where MFA is required.

ENT-001 / POS-001 / QUERY-001

- **Impact:** commercial/access bypass, incorrect offline actor evidence, stale or cross-context client data.
- **Recommendation:** durable default-deny entitlements; original actor and replayer separated; canonical tenant/session query-key prefix and cache reset.
- **Acceptance:** route/action/API/worker/read-model matrix passes negative tests for absent/suspended/expired modules; replay retains original actor; organization switch leaves no previous-organization cache entries.

REL-001 / OBS-001

- **Impact:** system may deploy without verified database history, secrets, alert delivery, recovery, provider authority, or expert statutory approval.
- **Recommendation:** clean production-shaped rehearsal with managed secrets, migrations/history, provider fixtures, logs/metrics/alerts, backup/restore, rollback, country-pack sources, and independent review.
- **Acceptance:** every external evidence group has immutable artifact, owner, timestamp, environment, command/result, and independent sign-off; no local/static assertion is promoted to production proof.

UX-001 / UX-002 / PROD-001

- **Impact:** broken user journeys, duplicated support/training, denial dead ends, misleading module status, no evidence of activation or retention.
- **Recommendation:** canonical route registry, safe redirects, internal-only demos, one acquisition funnel, access-aware setup, localized shell, five golden a11y journeys, minimal product telemetry.
- **Acceptance:** every route has owner/job/canonical status/permission/module/telemetry; broken links zero; setup never proposes an unavailable action; EN/FR golden journeys meet WCAG 2.2 AA evidence; activation baselines exist.

Unsafe or unverified acceptance work

The following were not executed because they require disposable infrastructure or would overwrite user evidence: real PostgreSQL tenant/concurrency tests, migration deploy/status, seeds, authenticated Playwright setup, provider calls, release gates, policy composite, load/credential attacks, SAST/SCA network operations, backup/restore drills, and statutory authority verification.